



HCM-UTE

TRƯỜNG ĐẠI HỌC

CÔNG NGHỆ KỸ THUẬT TP. HỒ CHÍ MINH

HCMC University of Technology and Engineering

AN TOÀN THÔNG TIN (INSE330380)

CHƯƠNG V PHẦN MỀM ĐỘC HẠI - MALWARE

Ths. ĐỖ MINH HẬU

- ☐ Giới thiệu bài học
- ☐ Giới thiệu phần mềm độc hại
- ☐ Các kiểu phần mềm độc hại và giải pháp ngăn chặn
- ☐ Virus, worm,....
- ☐ Phân tích phần mềm độc hại
- ☐ Các tấn công phổ biến và phòng chống
- ☐ Tóm tắt
- ☐ Quizze

- ❑ Có nhiều nguy cơ tới an toàn an ninh thông tin trên mạng, trong đó Mã độc là một trong những mối đe dọa lớn nhất trên internet, có thể gây thiệt hại lớn cho các tổ chức.
- ❑ Có rất nhiều phần mềm độc hại. Mỗi phần mềm được thiết kế ra với tính năng và mục đích khác nhau nhằm gây hại cho hệ thống mục tiêu
- ❑ Bên cạnh mã độc, các tấn công trên không gian mạng cũng rất đa dạng và tinh vi là mối lo ngại cho các tổ chức và doanh nghiệp

Phần mềm độc hại (malware- malicious software)

- ❑ Malware là phần mềm/mã độc được tạo ra nhằm xâm nhập, phá hoại, làm gián đoạn hoạt động, hoặc đánh cắp dữ liệu trên hệ thống.
- ❑ Tác hại có thể gặp (tùy loại malware):
 - Gây phiền nhiễu/lừa đảo: quảng cáo, cửa sổ giả mạo cảnh báo (adware, scareware)
 - Đánh cắp/thu thập thông tin: spyware, keylogger
 - Chiếm quyền điều khiển: trojan/backdoor, botnet
 - Phá hoại hoặc tống tiền: xóa/sửa dữ liệu, mã hóa đòi tiền chuộc (ransomware)
 - Tự lây lan sang máy khác: worm/virus (tùy cơ chế)
- ❑ Một số nơi trú ẩn của phần mềm độc hại là các file, thư mục hệ thống...

Malware có thể được phân loại theo nhiều tiêu chí, phổ biến gồm:

- Theo khả năng lây lan: có lây lan (Virus, Worm) / không tự lây lan (Trojan, Backdoor,..)
- Theo mục tiêu/hành vi: đánh cắp dữ liệu (Spyware), tống tiền (Ransomware), gây phiền nhiễu (Adware), ...
- Theo kỹ thuật ẩn mình/thực thi: Rootkit (ẩn mình), Fileless (thực thi chủ yếu trong bộ nhớ), ...

Phần tiếp theo sẽ chi tiết các phần mềm độc hại sau

- | | | |
|----------|------------|-------------------|
| ▪ Virus | ▪ Backdoor | ▪ Fileless |
| ▪ Worm | ▪ Botnet | ▪ Ransomware |
| ▪ Trojan | ▪ Rootkit | ▪ Adware, Spyware |

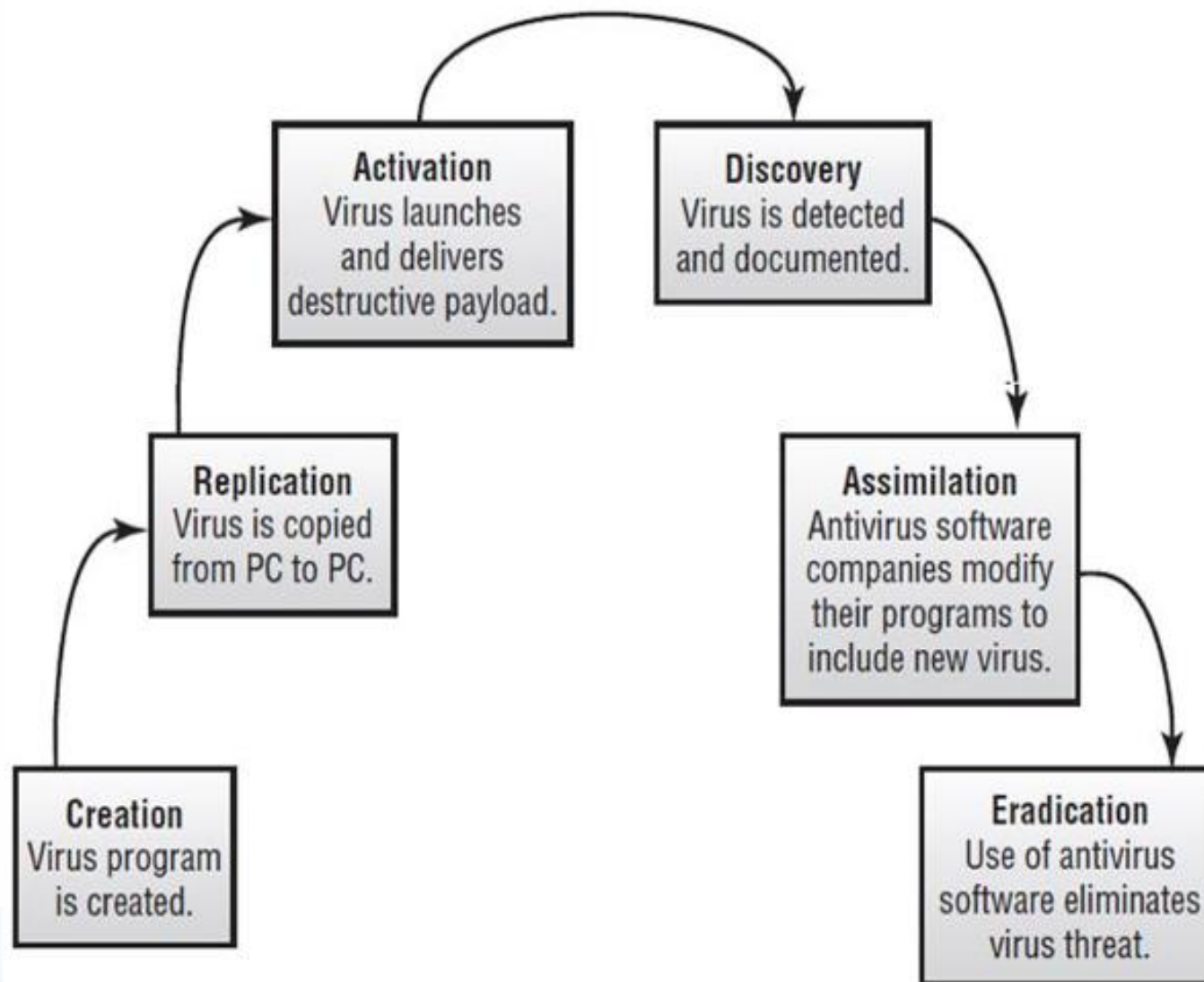
Virus là phần mềm độc hại:

- ☐ Virus máy tính là một loại mã độc ký sinh (parasitic malware), gắn vào một chương trình/tệp tin hợp pháp (host).
- ☐ Khi host được thực thi, virus có thể kích hoạt và chạy ẩn mà người dùng không nhận ra.
- ☐ Virus có khả năng tự nhân bản bằng cách sao chép mã của mình sang các đối tượng khác (tệp tin, vùng khởi động/boot sector, macro tài liệu...).

Virus là phần mềm độc hại:

- ☐ Thường phụ thuộc hành động người dùng để lây lan (mở file, chạy chương trình, bật macro...), khác với worm (tự lây qua mạng).
- ☐ Có thể được thiết kế để khai thác điểm yếu hoặc tận dụng quyền hạn có sẵn để thực hiện payload.
- ☐ Hậu quả: xóa/sửa dữ liệu, làm gián đoạn hệ thống, cài thêm mã độc khác, chiếm quyền điều khiển,...

6 giai đoạn



1. Giai đoạn không hoạt động (Dormant)

- Virus nằm im, chờ điều kiện phù hợp.
- Điều kiện có thể là ngày/giờ, sự tồn tại của một file/chương trình, số lần chạy, dung lượng đĩa, ...
- Không phải virus nào cũng có giai đoạn này.

2. Giai đoạn lây lan (Propagation / Infection)

- Virus tự sao chép và gắn vào chương trình/tệp khác hoặc một số vùng hệ thống (ví dụ boot/macro).
- Mục tiêu: tăng số đối tượng bị nhiễm.

3. Giai đoạn kích hoạt (Triggering / Activation)

- Virus được “đánh thức” khi đúng điều kiện kích hoạt (event-based).
- Điều kiện có thể đến từ hành vi người dùng (mở file, bật macro) hoặc sự kiện hệ thống.

4. Giai đoạn thực thi (Execution / Payload)

- Virus thực hiện payload: có thể “vô hại” (hiện thông báo) hoặc gây hại (phá hủy dữ liệu, làm gián đoạn hệ thống, cài thêm mã độc,...).

Virus máy tính được thiết kế gồm có ba phần:

- **Cơ chế lây nhiễm:** Cách virus xâm nhập, bám vào host và tự nhân bản/lây lan sang đối tượng khác (file, macro, boot...). “Vector lây nhiễm” thường dùng để chỉ con đường lây (USB, email, file chia sẻ...), còn “cơ chế lây nhiễm” là cách nó thực hiện lây (bám file, macro...).
- **Trình kích hoạt:** sự kiện hoặc điều kiện xác định thời điểm Payload được kích hoạt hoặc phân phối.
- **Payload:** Virus làm gì ngoài việc lây lan. Payload có thể liên quan đến hư hỏng hoặc có thể liên quan đến hoạt động lành tính nhưng đáng chú ý.

- ❑ Virus có thể được thêm vào trước hoặc sau vào một chương trình thực thi hoặc nó có thể được nhúng theo một số cách khác.
 - Chương trình bị nhiễm, khi được gọi, trước tiên sẽ thực thi mã virus và sau đó thực thi mã gốc của chương trình.

□ Virus V:

1: vào “main” của chương trình virus

2: một lá cờ đặc biệt (có bị nhiễm hay không)

□ Main:

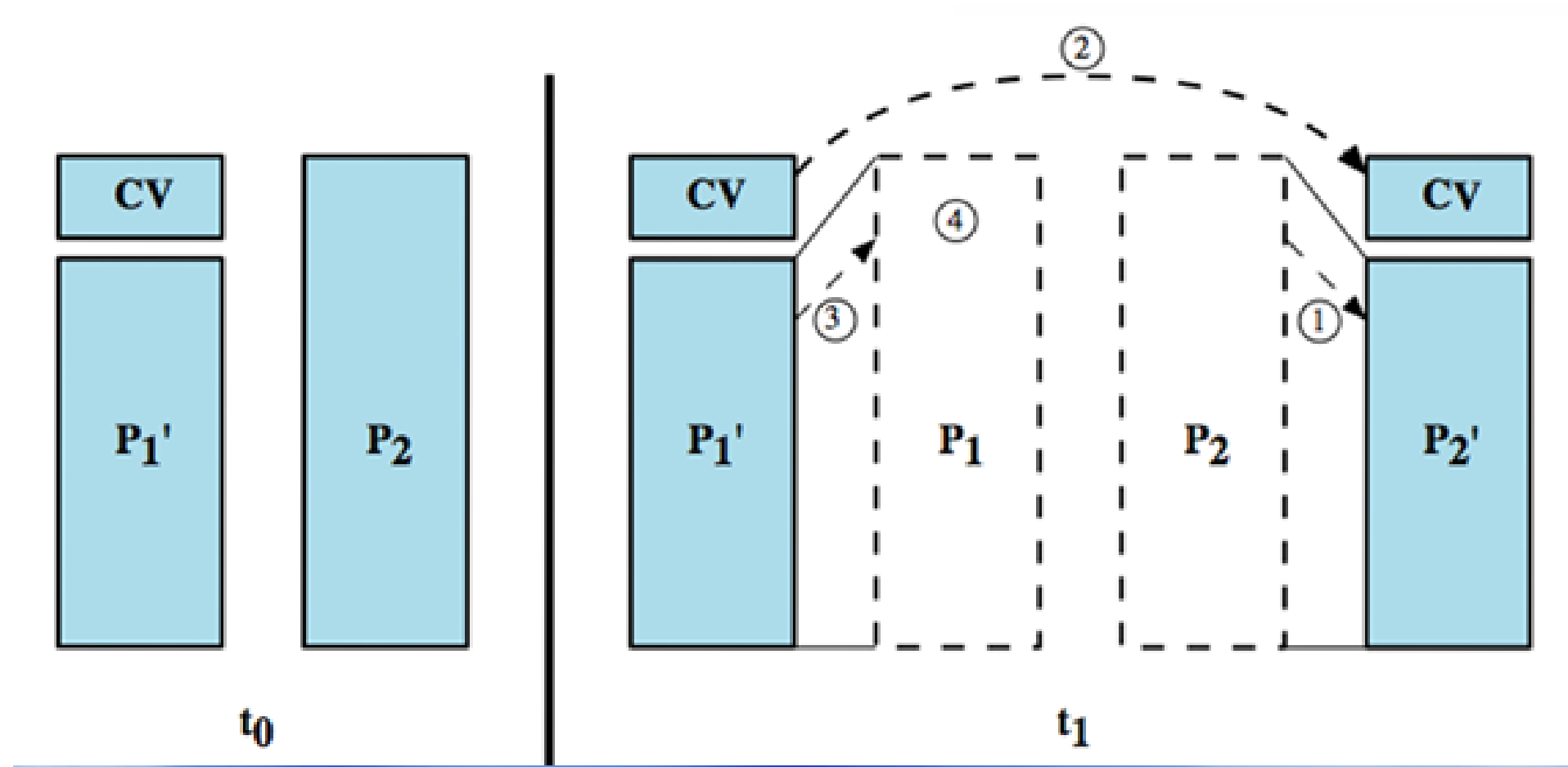
- Tìm các chương trình không bị nhiễm - lây nhiễm
- Làm điều gì đó gây tổn hại cho hệ thống
- Nhảy tới dòng đầu tiên của chương trình chủ
- làm việc bình thường

```
program V :=  
{goto main;  
 1234567;  
  
  subroutine infect-executable :=  
    {loop:  
      file := get-random-executable-file;  
      if (first-line-of-file = 1234567)  
        then goto loop  
        else prepend V to file; }  
  
  subroutine do-damage :=  
    {whatever damage is to be done}  
  
  subroutine trigger-pulled :=  
    {return true if some condition holds}  
  
main:  main-program :=  
  {infect-executable;  
   if trigger-pulled then do-damage;  
   goto next;}  
  
next:  
  
}
```

Để tránh bị phát hiện bằng cách nhìn vào kích thước của chương trình

- ❑ Nén tệp tin thực thi để cả hai phiên bản bị nhiễm và không nhiễm đều có cùng độ dài.
- ❑ Nén/giải nén chương trình chủ

```
program CV :=  
  
{goto main;  
 01234567;  
  
subroutine infect-executable :=  
  {loop:  
    file := get-random-executable-file;  
    if (first-line-of-file = 01234567) then goto loop;  
  (1)  compress file;  
  (2)  prepend CV to file;  
  }  
  
main:  main-program :=  
  {if ask-permission then infect-executable;  
  (3)  uncompress rest-of-file;  
  (4)  run uncompressed file;}  
}
```



Giả định rằng P1 bị nhiễm virus CV. Khi chương trình này được gọi, điều khiển sẽ chuyển sang virus của nó, thực hiện các bước sau:

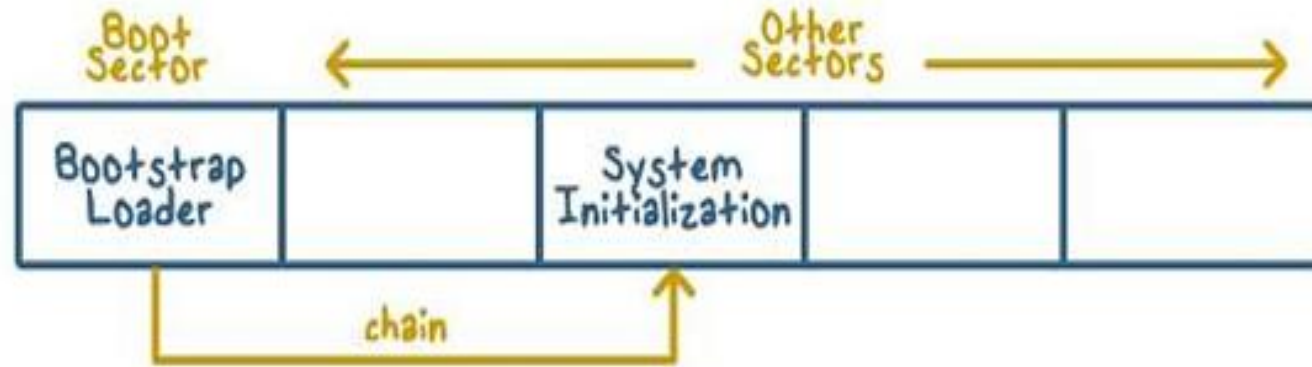
1. Tìm các tệp thực thi P2 chưa bị nhiễm (kiểm tra bằng dấu nhận diện/“cờ” đặc biệt).
2. Với mỗi P2 chưa nhiễm, virus nén phần chương trình chủ của P2 để tạo dung lượng trống (bù cho phần mã virus sẽ chèn thêm)
3. PVirus chèn một bản sao CV vào tệp đã nén $\rightarrow$ tạo tệp bị nhiễm $P2' = CV + (P2 \text{ ở dạng nén})$
4. Khi người dùng chạy P2', CV chạy trước, sau đó giải nén P2 và chuyển điều khiển để P2 chạy bình thường (giảm khả năng bị nghi ngờ khi chỉ nhìn kích thước file)

Dựa vào vị trí lây nhiễm của Virus, có các loại virus sau

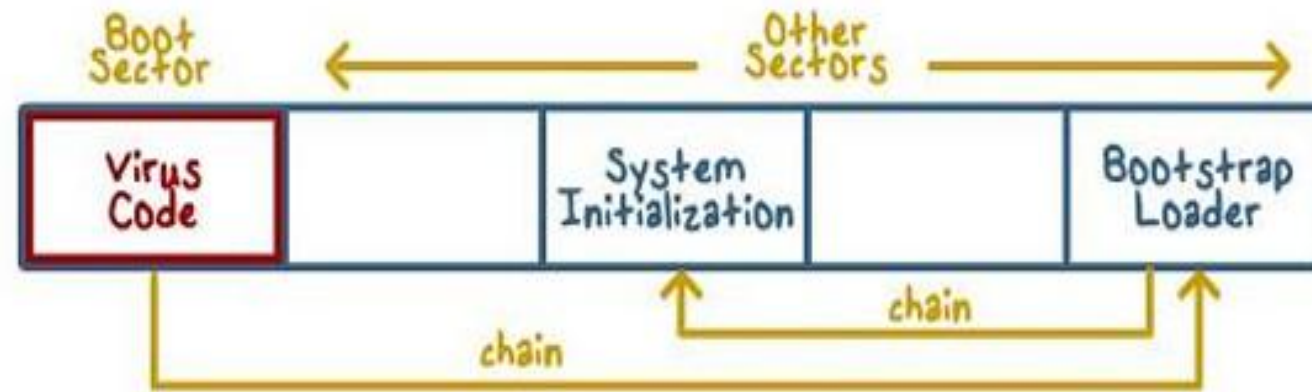
- Resident
- File Infector
- Multipartite
- Macro

Dựa vào chiến lược che giấu, có các loại virus sau

- Mã hóa – Encrypted
- Ẩn mình - Stealth
- Đa hình - Polymorphic
- Siêu đa hình - Metamorphic



(a) Before infection



(b) After infection

- ❑ Boot sector/MBR virus là mã độc ghi đè hoặc chèn vào MBR/VBR (boot sector) của thiết bị lưu trữ, để được nạp và chạy rất sớm trong quá trình khởi động (trước hệ điều hành).
- ❑ Cách Máy tính bị nhiễm virus boot Sector
 - Khởi động từ thiết bị/ổ đĩa đã bị nhiễm (USB/HDD/ổ ngoài) khi BIOS/UEFI cho phép boot từ thiết bị đó.
 - Lây qua thao tác ghi boot sector/MBR: khi người dùng/ phần mềm độc hại có quyền ghi đĩa, nó có thể chỉnh MBR/VBR.
 - Ngày nay loại này ít gặp hơn do UEFI + Secure Boot và cơ chế bảo vệ hệ điều hành, nhưng vẫn có biến thể kiểu bootkit.

❑ Phòng chống / xử lý

- Không boot từ USB/ổ lạ; tắt “boot from removable” nếu không cần.
- Bật Secure Boot/UEFI, cập nhật hệ điều hành; dùng AV/EDR có chức năng quét boot sector.
- Khi nghi nhiễm: quét offline/Rescue media, sao lưu dữ liệu; có thể cần khôi phục MBR/VBR theo quy trình chuẩn của hệ điều hành.

- ❑ **Memory-resident virus (virus thường trú bộ nhớ):** sau khi được kích hoạt, virus nạp vào RAM và duy trì hoạt động bằng cách móc (hook) các dịch vụ/hàm hệ thống để theo dõi sự kiện.
- ❑ **File infector (virus lây tệp):** virus lây vào tệp thực thi (ví dụ .exe/.com hoặc file tương tự tùy hệ điều hành), thường bằng cách chèn mã vào đầu/cuối hoặc thay đổi điểm vào (entry point)

- ❑ File Infector: Khái niệm: Virus lây tệp (file infector) là loại virus chèn/đính kèm mã của nó vào các tệp thực thi để phát tán khi người dùng chạy chương trình.
- ❑ Đối tượng thường gặp: các tệp thực thi như .exe, .com (và một số định dạng thực thi/khởi chạy khác tùy hệ điều hành, ví dụ .dll, script, ...)
- ❑ Cơ chế hoạt động:
 - Khi một tệp đã bị nhiễm được thực thi, virus được kích hoạt, có thể tìm và lây sang các tệp thực thi khác trong hệ thống (đặc biệt nếu virus có cơ chế thường trú trong RAM).
 - Việc lây nhiễm có thể làm tệp bị thay đổi, chạy bất thường hoặc không chạy được (do sửa entry point, chèn mã lỗi, hoặc ghi đè).

- ❑ **Multipartite:** Là virus có khả năng lây từ nhiều vị trí (ví dụ boot sector + file thực thi), nên có thể tái nhiễm chéo. Thường khiến việc làm sạch khó hơn vì không chỉ nằm ở một nơi.
- ❑ **Macro:** Là mã độc nhúng trong tài liệu có hỗ trợ macro (Word/Excel, v.v.). Lây/lan truyền chủ yếu qua tệp đính kèm email, chia sẻ nội bộ, tải xuống, và được kích hoạt khi người dùng bật macro

Với đặc tính che dấu của virus, nó sẽ tránh được sự phát hiện của các chương trình anti-virus. Có các loại sau:

- ❑ Mã hóa – Encrypted: Virus mã hoá phần thân (payload) để chữ ký (signature) khó bị nhận diện. Kèm theo một đoạn giải mã nhỏ (decryptor); khi chạy, decryptor giải mã payload trong bộ nhớ rồi thực thi. Mỗi lần lây, virus có thể dùng khóa/biến thể khác nhau, làm mẫu byte thay đổi → AV dựa vào chữ ký khó bắt hơn.
- ❑ Ẩn mình - Stealth: Virus che giấu sự hiện diện bằng cách đánh lừa hệ điều hành hoặc công cụ quét: Hook/đánh chặn thao tác đọc file, liệt kê thư mục, truy vấn tiến trình/registry. Trả về dữ liệu “sạch” (kích thước, checksum, nội dung...) để người dùng/AV thấy như bình thường. Mục tiêu là ẩn dấu vết, không phải “biến mất” bằng cách tự xoá.

- ❑ Đa hình - Polymorphic: Virus tự thay đổi hình dạng ở mỗi lần lây để tạo ra mẫu byte khác nhau (signature khó khớp). Thường dùng: mã hoá payload + decryptor tự biến đổi (thêm rác, đổi lệnh tương đương, đổi khóa...). Vì vậy, phát hiện bằng chữ ký tĩnh khó hơn; AV thường cần heuristic/behavior + emulation.
- ❑ Biến hình - Meta-polymorphic: Virus tự viết lại/biến đổi chính mã của nó (recode), nhưng vẫn giữ nguyên chức năng. Có thể dùng các kỹ thuật như: đổi thứ tự khối lệnh, thay thế lệnh tương đương, đổi thanh ghi, chèn/loại bỏ mã “rác”, thay đổi luồng điều khiển. Né tránh chữ ký mạnh hơn polymorphic vì không chỉ đổi phần decryptor.

□ Một số giải pháp đối phó với virus:

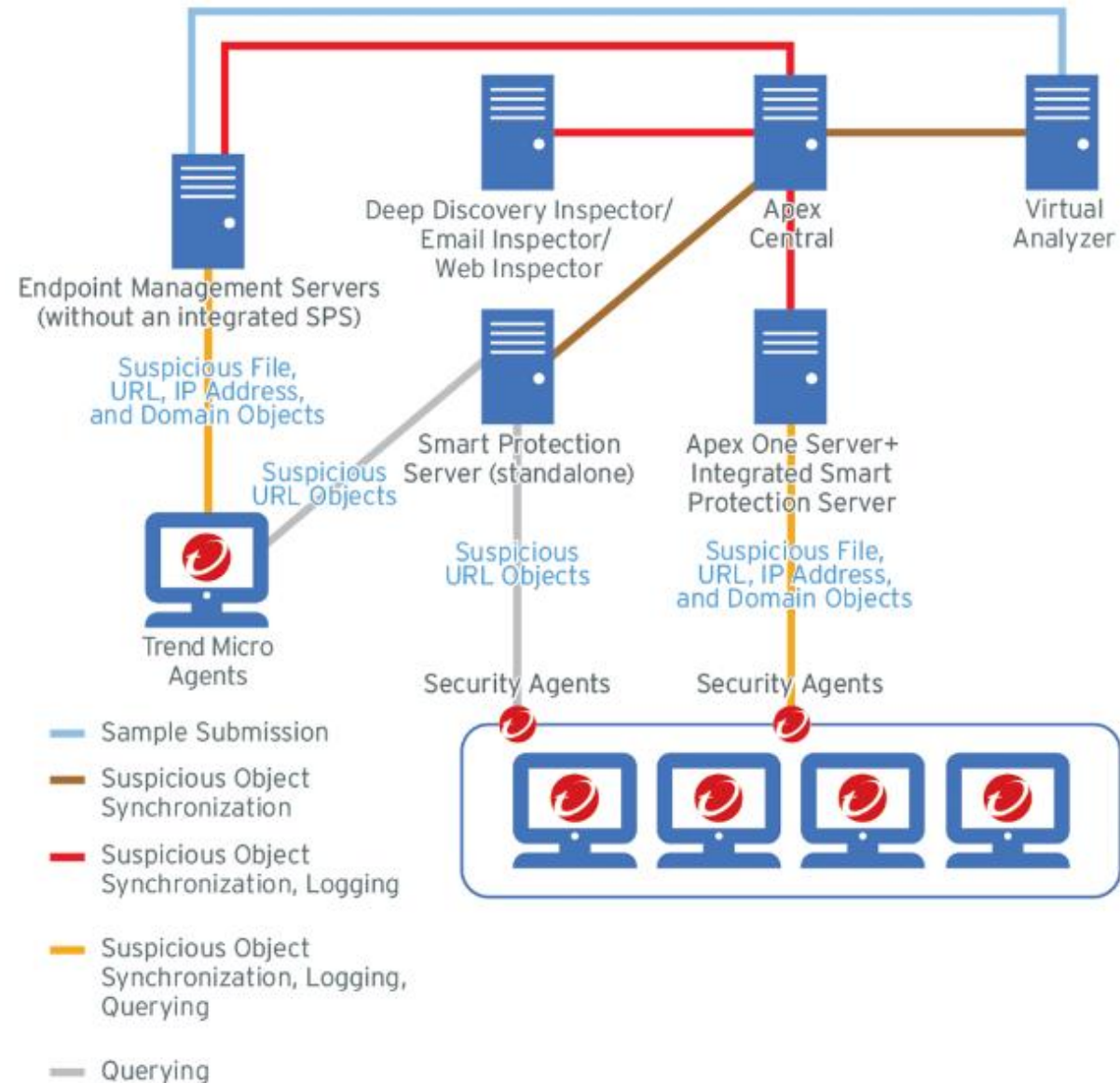
- Phần mềm bảo mật (Anti-virus/Endpoint Security): ví dụ Kaspersky, Bitdefender, Microsoft Defender, ESET, BKAV...(Norton, McAfee cũng thuộc nhóm này)
- Cập nhật & vá lỗi (Patch management): cập nhật hệ điều hành, trình duyệt, Office để giảm khai thác lỗ hổng.
- Phát hiện theo chữ ký (Signature-based) + Heuristic/ML: nhận diện mẫu đã biết và mẫu “giống đáng ngờ”.

❑ Một số giải pháp đối phó với virus:

- Giám sát hành vi (Behavior blocking / EDR): chặn hành vi nguy hiểm (mã hoá hàng loạt file, tiêm mã, persistence...).
- Giải mã/giả lập để phát hiện mã độc mã hoá (Generic decryption / Emulation): chạy “giả lập” để thấy payload sau khi tự giải mã.
- Lọc email & web / sandbox: chặn/phân tích file đính kèm, link độc hại trước khi tới người dùng.

Mô hình triển khai Trendmicro

Hệ thống triển khai theo mô hình
client – server có thể hỗ trợ phân
cấp nhiều server



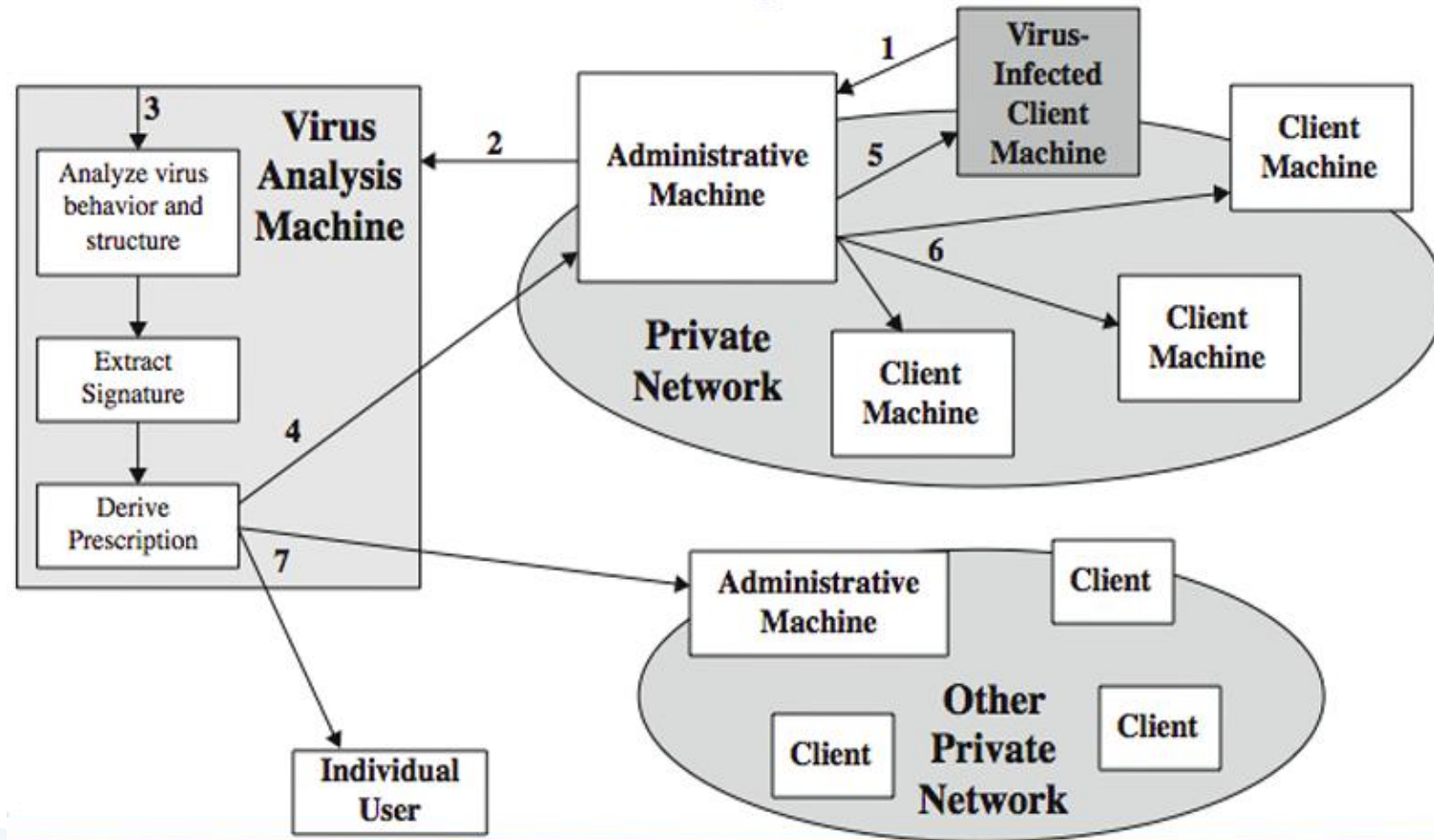
❑ Công nghệ giải mã chung (GD):

- Cho phép phát hiện ngay cả những vi-rút đa hình phức tạp nhất, trong khi vẫn duy trì tốc độ quét nhanh.

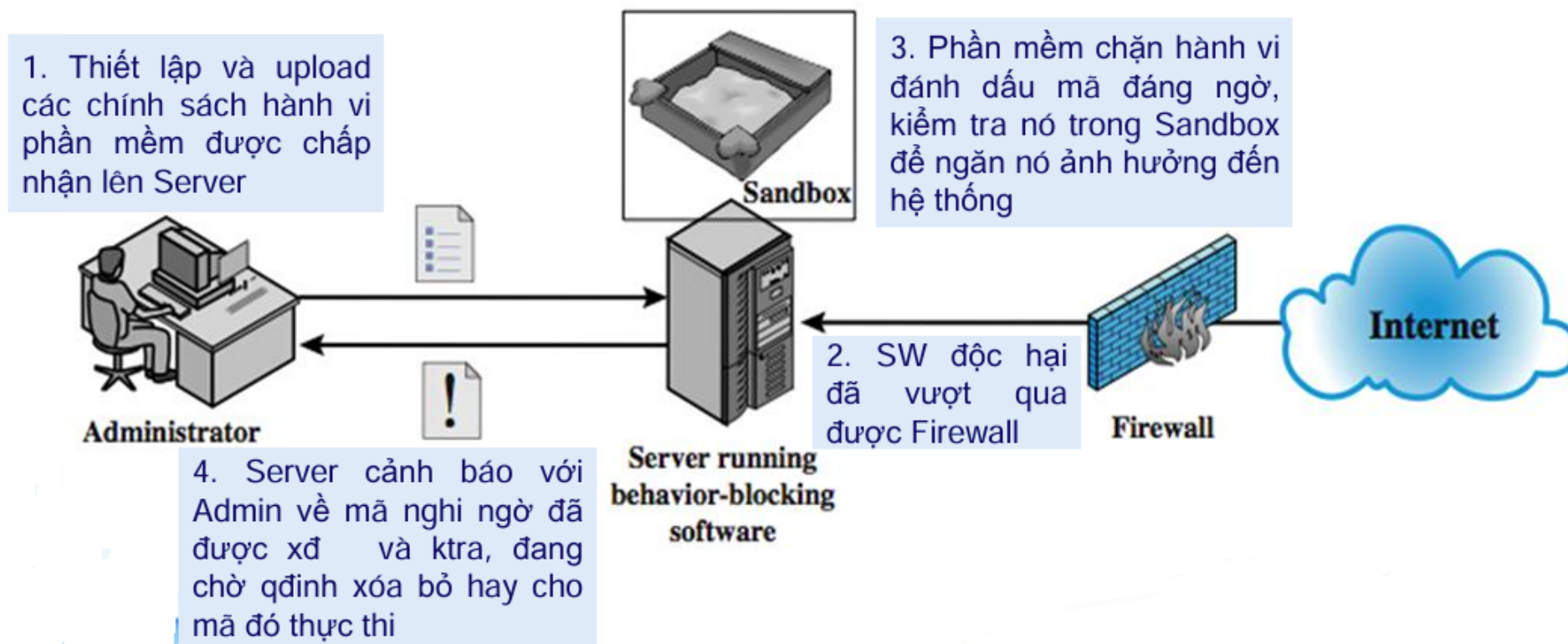
❑ Để phát hiện vi-rút được mã hóa, các tệp thực thi được chạy qua trình quét GD:

- Trình mô phỏng CPU: Một máy tính ảo dựa trên phần mềm diễn giải các hướng dẫn trong một tệp thực thi thay vì thực thi chúng trên bộ xử lý cơ bản.
- Trình quét dấu hiệu virus: quét mã mục tiêu để tìm kiếm các dấu hiệu virus đã biết.
- Mô-đun điều khiển mô phỏng: Điều khiển việc thực thi mã đích. Khi bắt đầu mỗi mô phỏng, trình mô phỏng bắt đầu diễn giải từng chỉ thị trong mã đích.

Hệ thống miễn dịch kỹ thuật số: tự động thu thập virus, phân tích, bổ sung tính năng dò tìm và che giấu, loại bỏ nó và cảnh báo thông tin về virus này sang hệ thống khác



Phần mềm chặn hành vi sẽ chặn các hành động độc hại trước khi chúng có thể ảnh hưởng đến hệ thống, như: Cố gắng mở, xem, xóa, và / hoặc sửa đổi các tập tin, ổ đĩa...



- ❑ Worm (sâu máy tính): malware tự nhân bản và tự lan truyền qua mạng.
- ❑ Khác virus: worm chạy độc lập, thường không cần người dùng kích hoạt để phát tán.
- ❑ Tác hại: có thể xóa/sửa dữ liệu, cài backdoor; đặc biệt lây lan rất nhanh, tổn băng thông, làm quá tải hệ thống/dịch vụ.
- ❑ Ví dụ: Morris, Code Red, SQL Slammer, Mydoom.

Các dạng worm có thể chi thành 3 nhóm:

- ☐ Theo phạm vi/nền tảng: Multiplatform (Windows, LINUX...)
- ☐ Theo cơ chế lây/khai thác: Đa khai thác, Lan rộng cực nhanh, Zero-day
- ☐ Theo payload & né phát hiện: Phương tiện vận tải, Đa hình, Siêu đa hình

□ Giải pháp ngăn chặn: tương tự các kỹ thuật anti-virus, như

- Signature-based: quét/chặn theo chữ ký worm đã biết.
- Filtering (FW/IPS): chặn theo rule (port/protocol/payload pattern).
- Anomaly/Behavior-based: phát hiện quét mạng, bùng nổ kết nối, hành vi tự nhân bản.
- Thresholding (dynamic baseline): cảnh báo/chặn khi vượt ngưỡng bất thường (kết nối/giây, SYN rate...).
- Rate limiting / throttling: giới hạn tốc độ tạo kết nối & lưu lượng để kìm lan truyền.
- Patch & hardening: cập nhật OS/phần mềm, tắt dịch vụ không cần, phân đoạn mạng.

- ❑ Trojan: mã độc giả dạng phần mềm hợp pháp (game, “antivirus”, crack...).
- ❑ Đặc điểm: thường không tự nhân bản; cần người dùng chạy/cài để hoạt động.
- ❑ Lây nhiễm: email/file đính kèm, link độc hại, tải phần mềm crack, drive-by download (khi có lỗ hổng).
- ❑ Hậu quả: xoá/ghi đè dữ liệu, cài backdoor, tải thêm malware, tạo botnet (DDoS/spam), keylogging ăn cắp mật khẩu.

- ❑ Khi nhiễm Trojan, máy nạn nhân có thể có các dấu hiệu:
 - Hiệu năng giảm, tăng CPU/RAM/Network bất thường
 - Chương trình/tiến trình lạ tự chạy, tự khởi động cùng hệ thống
 - Kết nối ra ngoài bất thường (C2), DNS/Proxy lạ
 - Trình duyệt bị can thiệp (redirect, extension lạ)
 - AV/Firewall bị tắt, khó cập nhật hệ thống
- ❑ Phương pháp đối phó với Trojan: tương tự như với Virus và Worm.

- ❑ Backdoor/Trapdoor: cơ chế hoặc đoạn mã tạo đường truy cập ẩn vào hệ thống, cho phép bỏ qua hoặc làm suy yếu kiểm soát truy cập (xác thực/phân quyền).
- ❑ Backdoor độc hại: kẻ tấn công cài để truy cập từ xa, duy trì hiện diện, thường dùng để điều khiển máy, đánh cắp dữ liệu, cài thêm mã độc.
- ❑ Trapdoor “hợp pháp”: chức năng debug/maintenance do nhà phát triển để lại; nếu không quản lý chặt (MFA, giới hạn IP, logging, vô hiệu hoá khi release) thì trở thành lỗ hổng nghiêm trọng.

- ❑ Backdoor có mục đích xấu: kẻ tấn công cài lên máy nạn nhân để tạo kênh truy cập trái phép từ xa. Backdoor thường được triển khai thông qua Trojan điều khiển từ xa (RAT – Remote Access Trojan) để điều khiển máy, cài thêm mã độc hoặc đánh cắp dữ liệu.
- ❑ Giải pháp ngăn chặn: không sử dụng các phần mềm không đáng tin cậy, không truy cập vào các website nguy hiểm. Ngoài ra sử dụng các giải pháp tương tự như đối với Virus, Worm...

- ❑ Rootkit: tập hợp kỹ thuật/công cụ giúp kẻ tấn công ẩn mình và duy trì quyền truy cập/đặc quyền cao trên hệ thống.
- ❑ Cài đặt: qua lỗ hổng, lừa người dùng chạy mã độc, hoặc sau khi đã chiếm quyền (privilege escalation).
- ❑ Kỹ thuật: hook API/system call, ẩn file/tiến trình/kết nối, can thiệp driver/kernel, có thể vô hiệu hoá cơ chế bảo vệ.
- ❑ Phân loại: user-mode, kernel-mode, bootkit/UEFI.
- ❑ Đối phó: patch + EDR, Secure Boot; khi nghi nhiễm nặng → quét offline và thường reimage từ bản sạch.

- ❑ Fileless là kỹ thuật/mã độc ưu tiên thực thi trong bộ nhớ (in-memory) và tận dụng công cụ hợp pháp của hệ điều hành (Living-off-the-Land) để giảm dấu vết file trên ổ đĩa.
- ❑ Không phụ thuộc vào tệp thực thi truyền thống; thay vào đó dùng các “non-file artifacts” như:
 - Registry keys, WMI, Scheduled Tasks/Services
 - API, script engine, cơ chế nạp mã trong tiến trình hợp pháp
- ❑ Nhiều cuộc tấn công fileless bắt đầu bằng việc lợi dụng chương trình hợp pháp và tạo tiến trình con để chạy payload (ví dụ: PowerShell, wscript/mshta, rundll32...).
- ❑ Khó phát hiện và ngăn chặn bằng phương pháp dựa trên chữ ký file; cần tập trung vào giám sát hành vi + logging (process, command line, network, persistence).

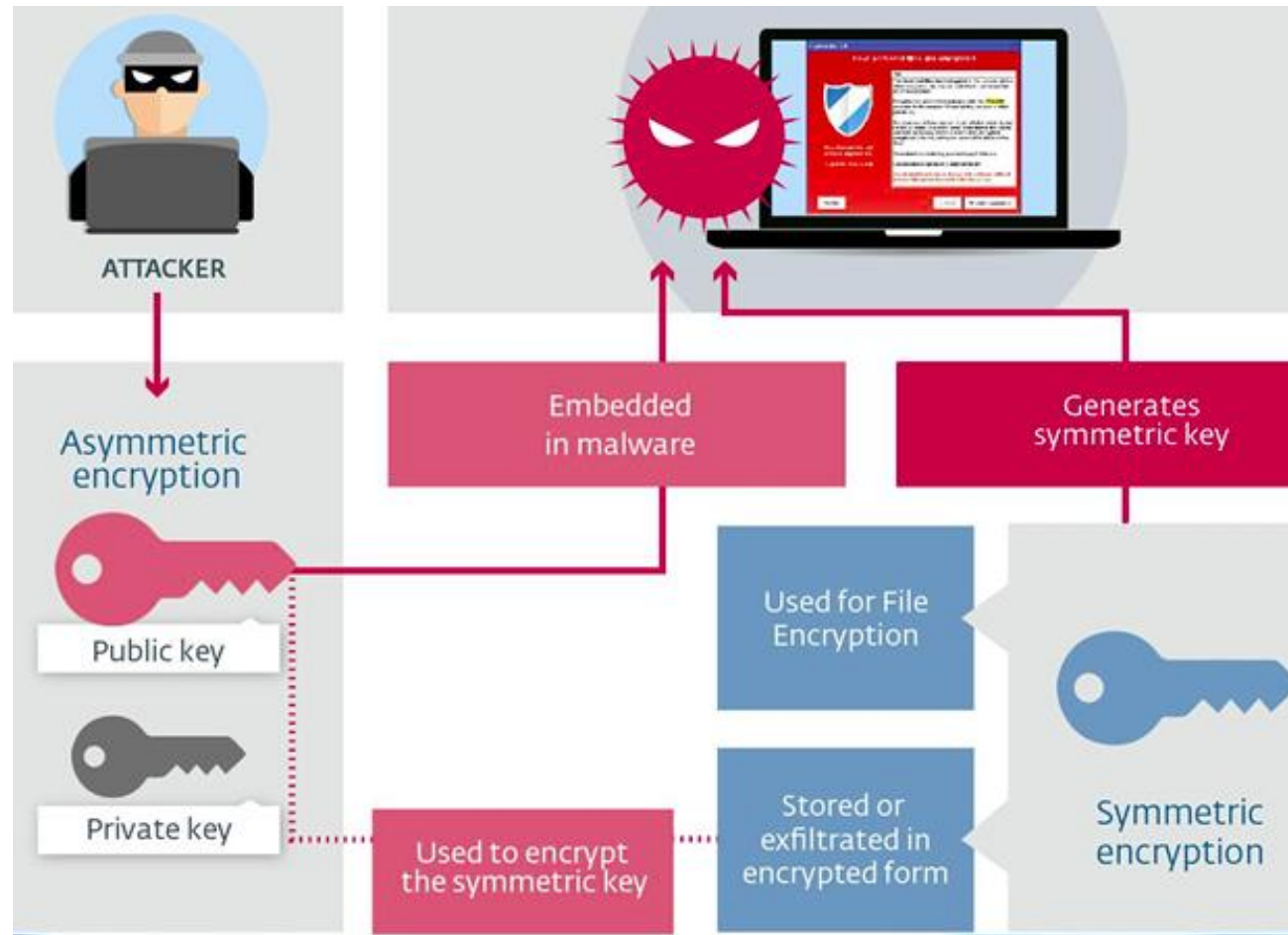
- ❑ Ransomware là mã độc mã hoá dữ liệu hoặc khóa quyền truy cập hệ thống/tệp, khiến nạn nhân không thể sử dụng dữ liệu.
- ❑ Sau khi thực thi, ransomware yêu cầu tiền chuộc (thường bằng tiền điện tử) để cung cấp khóa giải mã/khôi phục truy cập.
- ❑ Phương thức xâm nhập phổ biến:
 - Phishing/email đính kèm, tải phần mềm không tin cậy
 - Khai thác lỗ hổng (OS/ứng dụng/VPN)
 - Lộ mật khẩu/chiếm tài khoản (RDP, VPN), rồi di chuyển ngang trong mạng

- ❑ Biến thể hiện đại: double extortion — đánh cắp dữ liệu + mã hoá, đe dọa công bố nếu không trả tiền.
- ❑ Đối tượng bị ảnh hưởng: máy tính cá nhân, server, hệ thống doanh nghiệp, thiết bị và dịch vụ mạng.

- ❑ **Crypto ransomware (Crypto-malware):** mã hoá tệp/thư mục/ổ đĩa của nạn nhân; yêu cầu tiền chuộc (thường bằng tiền điện tử) để cung cấp khoá giải mã.
- ❑ **Locker ransomware (Screen/System locker):** khóa thiết bị hoặc phiên đăng nhập, khiến người dùng không truy cập được hệ điều hành/ứng dụng (không nhất thiết mã hoá dữ liệu).
- ❑ **Scareware:** giả mạo antivirus/cleanup tool, hiển thị cảnh báo “máy bị nhiễm” và ép trả tiền; thường là lừa đảo hoặc phần mềm không mong muốn, đôi khi không mã hoá dữ liệu.

- ❑ **Doxware / Leakware (Extortionware):** đánh cắp dữ liệu và đe dọa công bố/rò rỉ nếu không trả tiền chuộc (thường đi kèm mã hoá: double extortion).
- ❑ **RaaS (Ransomware-as-a-Service):** mô hình “dịch vụ” — nhóm phát triển cung cấp ransomware + hạ tầng/“cổng” quản lý; các đối tác triển khai tấn công và chia phần tiền chuộc.
- ❑ **Theo nền tảng mục tiêu:**
 - **macOS ransomware:** ransomware nhắm vào hệ điều hành macOS.
 - **Mobile ransomware:** ransomware nhắm vào thiết bị di động (Android/iOS), thường khoá màn hình/đòi tiền hoặc lạm dụng quyền truy cập.

Sơ đồ mã hóa kép trong phần mềm mã hóa-ransomware



Một số giải pháp giảm thiểu và ngăn chặn Ransomware



Back Up and Restore
Automated: 3 copies, 2 formats,
1 air-gapped from network



Control Access
Limit access to business-critical
data



Patch
Minimize vulnerability exploitation



Don't Pay the Ransom
Pay-offs encourage further
attacks



Educate employees on phishing
Awareness, best practices,
simulation testing



Improve Security Posture
Behavior monitoring, additional
technologies

❑ Adware:

- Là một trong những loại phần mềm độc hại phục vụ các cửa sổ bật lên và quảng cáo hiển thị hình ảnh thường không liên quan đến người dùng.
- Gây khó chịu và làm chậm máy của người dùng, nó liên kết đến các trang web mã độc để lừa người dùng tải xuống.
- Có thể cung cấp phần mềm gián điệp (Spyware) và thường dễ dàng bị tấn công, khiến các thiết bị có cài đặt phần mềm này trở thành mục tiêu cho tin tặc, kẻ lừa đảo.

□ Spyware:

- Bí mật ghi lại hoạt động trực tuyến của nạn nhân, thu thập dữ liệu và thông tin cá nhân như tên người dùng, mật khẩu và thói quen lướt web.
- Chuyển dữ liệu của nạn nhân tới các nhà quảng cáo hoặc tội phạm mạng, hoặc nó cài đặt thêm phần mềm độc hại làm thay đổi cài đặt máy nạn nhân

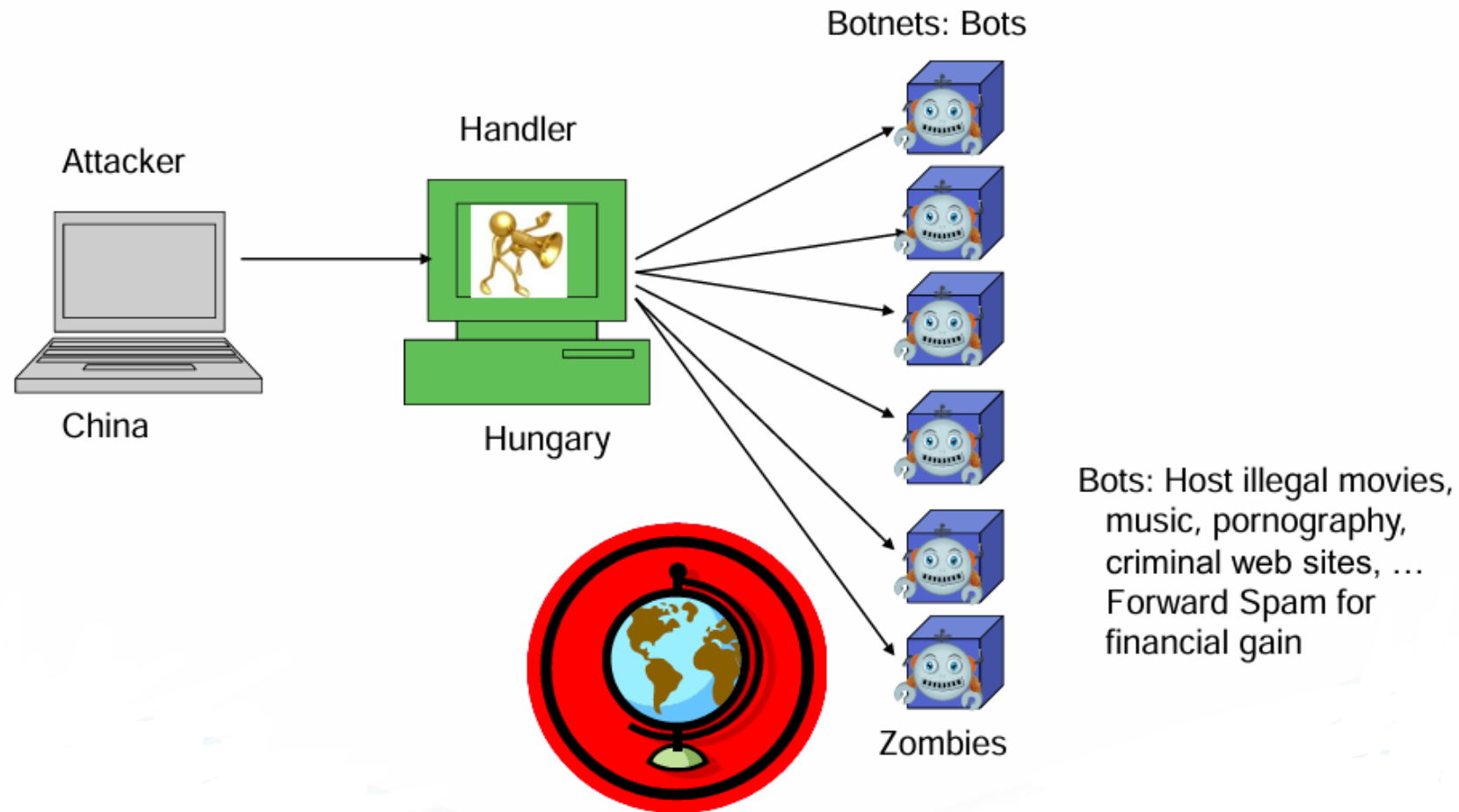
❑ Keylogger :

- Có thể là phần mềm hoặc phần cứng giám sát hoạt động bàn phím của người dùng và lưu giữ lại.
- Keylogger: dựa trên phần mềm ẩn mình bên trong hệ điều hành, chương trình cấp nhân, ứng dụng đang chạy và trình duyệt web của thiết bị bị nhiễm.
- Là mối đe dọa đối với những người và tổ chức sử dụng chúng vì các loại thông tin mà chúng đánh cắp

- ❑ Bot: thiết bị bị nhiễm mã độc, cho phép kẻ tấn công điều khiển từ xa và thực thi lệnh (ẩn danh qua nhiều lớp trung gian).
- ❑ Botnet: mạng lưới gồm nhiều bot bị điều khiển tập trung hoặc phân tán (C&C).
- ❑ Đặc điểm của Botnet:
 - ❑ Có kênh Command & Control (C&C) để nhận lệnh: HTTP(S)/DNS, hoặc mô hình P2P.
 - ❑ Có cơ chế lây lan/tuyển mộ bot mới: khai thác lỗ hổng, dò quét mật khẩu yếu, phát tán qua email/tải về.
 - ❑ Thường có kỹ thuật ẩn mình & né tránh phát hiện (evasion) và duy trì tồn tại (persistence).

❑ Một số hoạt động/tấn công thường gặp:

- DDoS, gửi spam/phishing.
- Đánh cắp thông tin (credential theft, keylogging, sniffing lưu lượng).
- Phát tán mã độc/tải thêm payload, cài adware/tiện ích trình duyệt trái phép.



- ❑ Là quá trình tìm hiểu hành vi và mục đích của một tệp hoặc URL đáng ngờ.
- ❑ Kết quả phân tích giúp phát hiện, ngăn chặn và giảm thiểu các mối đe dọa tiềm ẩn.
- ❑ Lợi ích chính của phân tích phần mềm độc hại đối với đội ứng phó sự cố và nhà phân tích bảo mật:
 - Phân loại và đánh giá mức độ nghiêm trọng của sự cố chính xác hơn
 - Khám phá Indicators of Compromise (IOCs) cần được chặn/giám sát
 - Cải thiện chất lượng cảnh báo, rule phát hiện và chia sẻ IOC
 - Làm phong phú bối cảnh (context) phục vụ threat hunting

□ Phân tích tĩnh

- Không yêu cầu mẫu/mã độc phải chạy thực sự.
- Kiểm tra tệp (sample) để tìm các dấu hiệu độc hại: chuỗi (strings), metadata, hàm/API, cấu trúc PE/ELF, tài nguyên nhúng,...
- Hữu ích để nhận diện nhanh: packer/obfuscation, thư viện sử dụng, IOC (domain/IP/URL), và dấu vết hạ tầng liên quan.
- Giới hạn: mã độc phức tạp có thể ẩn hành vi ở thời gian chạy (giải mã/giải nén khi chạy, kích hoạt theo điều kiện, anti-VM/anti-debug), nên phân tích tĩnh có thể không thấy đầy đủ hành vi.

□ Phân tích động

- Phân tích bằng cách chạy mẫu nghi ngờ trong môi trường cô lập (sandbox).
- Cho phép quan sát hành vi khi thực thi: tiến trình, file/registry, kết nối mạng, tạo persistence, hành vi tải thêm payload,...
- Giúp chuyên gia bảo mật theo dõi hoạt động mã độc với rủi ro lây lan được kiểm soát, tránh ảnh hưởng hệ thống thật/mạng doanh nghiệp.
- Giới hạn: một số mã độc có thể phát hiện sandbox/VM, trì hoãn hành vi (sleep), hoặc chỉ kích hoạt theo điều kiện nên kết quả có thể không đầy đủ.

□ Phân tích kết hợp (bao gồm cả hai kỹ thuật trên)

1. Phân tích thuộc tính tĩnh (Static Properties)

- ☐ Xem xét chuỗi (strings) được nhúng, thông tin header (PE/ELF), hàm băm (MD5/SHA-256), siêu dữ liệu, import/export, chữ ký số, packer/obfuscation, v.v.

2. Phân tích hành vi & tương tác (Behavior / Interactive Analysis)

- ☐ Quan sát thay đổi trên hệ thống: registry, hệ thống tệp, tiến trình/dịch vụ, tác vụ định kỳ, và lưu lượng mạng (DNS/HTTP(S)/C2).
- ☐ Phân tích bộ nhớ (memory analysis) để tìm dấu vết chỉ xuất hiện khi chạy: unpack trong RAM, code injection, khóa/chuỗi giải mã, kết nối C2, thông tin đăng nhập bị trộm,...
- ☐ Đòi hỏi kỹ năng phân tích cao, thường tốn thời gian và phức tạp → hiệu quả hơn khi kết hợp công cụ tự động (sandbox/EDR) và phân tích thủ công khi cần.

3. Phân tích hoàn toàn tự động (Automated Analysis)

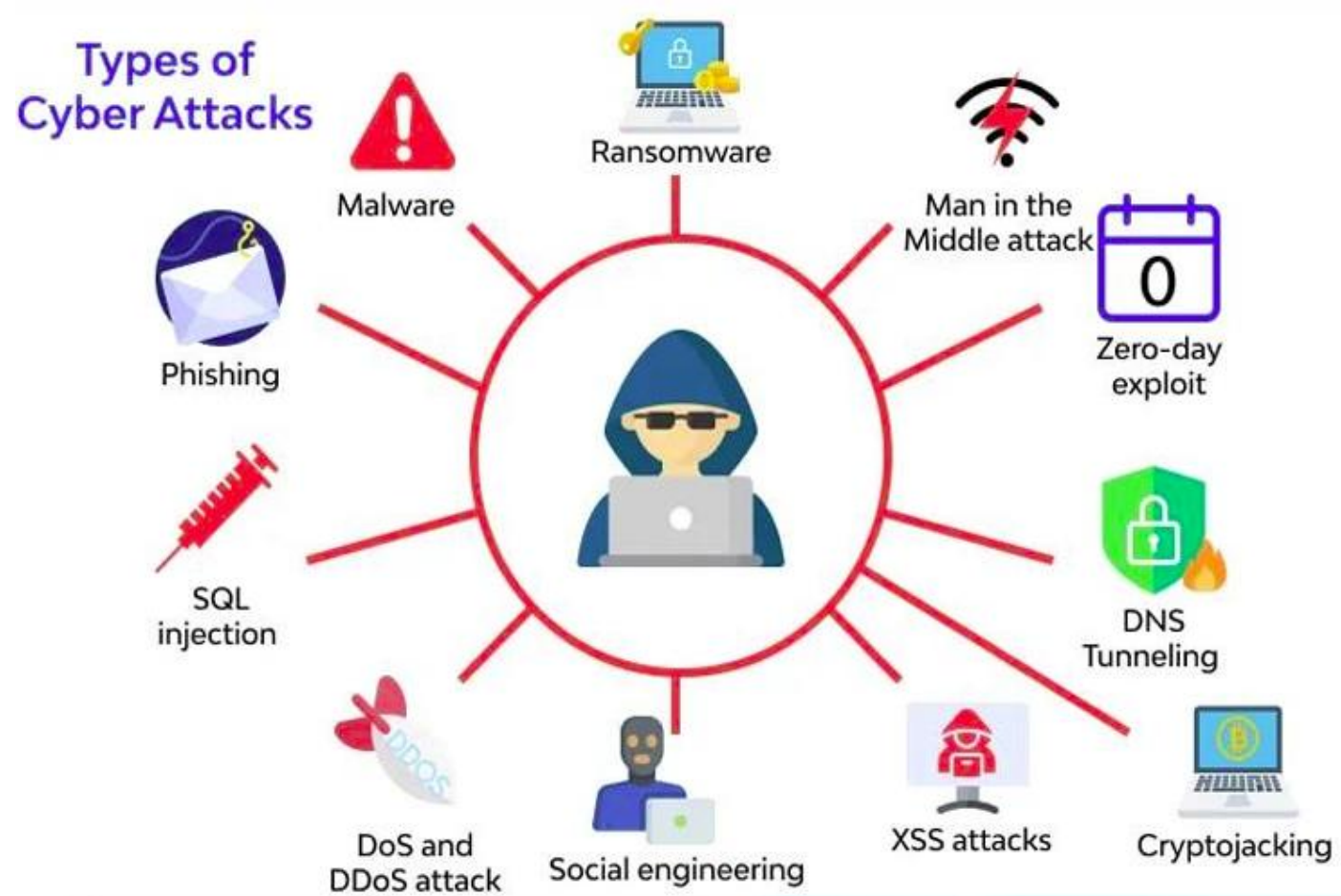
- ☐ Giúp đánh giá nhanh các tệp đáng ngờ (hành vi, IOC, mức độ rủi ro) với ít thao tác thủ công.
- ☐ Phù hợp nhất để xử lý quy mô lớn (lọc/triage nhiều mẫu, ưu tiên mẫu cần phân tích sâu).

4. Đảo ngược mã thủ công (Manual Reverse Engineering)

- ☐ Sử dụng debugger, disassembler/decompiler và công cụ chuyên dụng để:
- ☐ Giải mã/giải nén dữ liệu bị mã hóa/đóng gói (packed/obfuscated)
- ☐ Xác định logic/thuật toán và luồng điều khiển của mã độc
- ☐ Hiểu các khả năng ẩn mà phân tích tự động hoặc sandbox chưa quan sát được (kích hoạt theo điều kiện, anti-analysis, payload theo giai đoạn)

- ❑ Phát hiện phần mềm độc hại: xác định mẫu độc hại, phân loại họ mã độc, trích xuất IOC/TTP phục vụ phát hiện.
- ❑ Cảnh báo & xử lý mối đe dọa (EDR/SIEM): làm giàu ngữ cảnh (context) và ưu tiên cảnh báo chính xác hơn, giảm false positive và tiết kiệm thời gian xử lý.
- ❑ Ứng phó sự cố (Incident Response): hỗ trợ điều tra nguyên nhân gốc rễ (Root Cause Analysis) và khoanh vùng phạm vi ảnh hưởng.
- ❑ Săn lùng mối đe dọa (Threat Hunting): tìm hoạt động tương tự dựa trên dấu vết như domain/IP/URL, cổng, kết nối mạng, hành vi tiến trình.
- ❑ Nghiên cứu mã độc (Malware Research): cập nhật kỹ thuật/khai thác/công cụ mới, xây dựng quy tắc phát hiện và chia sẻ tình báo.

- ❑ Mã độc thế hệ mới, ưu tiên lẫn tránh phát hiện, thích nghi môi trường, tấn công nhiều giai đoạn để đạt mục tiêu (chiếm quyền/đánh cắp dữ liệu/đòi tiền).
- ❑ Đặc điểm chính:
 - ❑ Evasion/Anti-analysis: obfuscation/packing, mã hóa, anti-VM/sandbox/debug
 - ❑ Multi-stage & modular: loader → tải payload, dùng plugin/cập nhật từ xa
 - ❑ Living-off-the-Land (LotL): lạm dụng công cụ hợp pháp (PowerShell, WMI, rundll32...)
 - ❑ C2 tinh vi: dùng HTTPS/DNS/cloud, thay đổi hạ tầng linh hoạt
- ❑ Hệ quả: khó phát hiện bằng chữ ký đơn thuần → cần kết hợp static + dynamic + threat intel/EDR



❑ Là tập hợp kỹ thuật nhằm chiếm quyền truy cập bằng cách thu được hoặc vượt qua cơ chế mật khẩu, qua đó giả mạo người dùng hợp pháp.

❑ Nguồn/đường tấn công phổ biến:

- Social Engineering: lừa người dùng cung cấp mật khẩu/OTP.
- Rò rỉ dữ liệu: đánh cắp thông tin đăng nhập hoặc hash mật khẩu từ CSDL/hệ thống.

❑ Các dạng tấn công mật khẩu:

- Non-Electronic: khai thác thói quen, giấy ghi mật khẩu, quan sát (shoulder surfing)...
- Active Online: thử đăng nhập trực tiếp vào dịch vụ (bị giới hạn bởi lockout/rate limit).
- Passive Online: thu thập thông tin xác thực khi truyền/quá cơ chế xác thực yếu.
- Default Password: dùng mật khẩu mặc định/chưa đổi của thiết bị/dịch vụ.
- Offline: tấn công trên dữ liệu đã lấy được (ví dụ: hash), không tương tác trực tiếp với hệ thống.

- ☐ Dùng mật khẩu mạnh & duy nhất cho mỗi tài khoản (câu dài, khó đoán).
- ☐ Bật xác thực đa yếu tố (MFA/2FA), ưu tiên ứng dụng/khóa bảo mật.
- ☐ Dùng trình quản lý mật khẩu (password manager) để lưu & tạo mật khẩu an toàn.
- ☐ Không dùng mật khẩu mặc định, đổi ngay khi cài đặt thiết bị/dịch vụ.
- ☐ Cảnh giác phishing: kiểm tra link/domain trước khi đăng nhập, không nhập mật khẩu theo email/tin nhắn.
- ☐ Thận trọng khi mở email/tệp đính kèm, không tải file từ nguồn không tin cậy.

❑ DoS là kiểu tấn công làm cạn kiệt tài nguyên (băng thông/CPU/RAM/kết nối) khiến hệ thống chậm, gián đoạn hoặc không thể cung cấp dịch vụ.

❑ Dấu hiệu thường gặp:

- Hiệu năng giảm bất thường, phản hồi chậm
- Không truy cập được website/dịch vụ (timeout/503)
- Kết nối mạng chập chờn, rớt kết nối có dây/không dây
- Tài nguyên bị cạn (CPU/RAM/băng thông/connection limit)
- Nhiều yêu cầu bất thường tăng đột biến trong log/monitoring

Mục tiêu của tấn công DoS

☐ Tài nguyên Back-end:

- Website / API
- Cơ sở dữ liệu (DB)
- Cụm máy chủ / ứng dụng (server cluster)

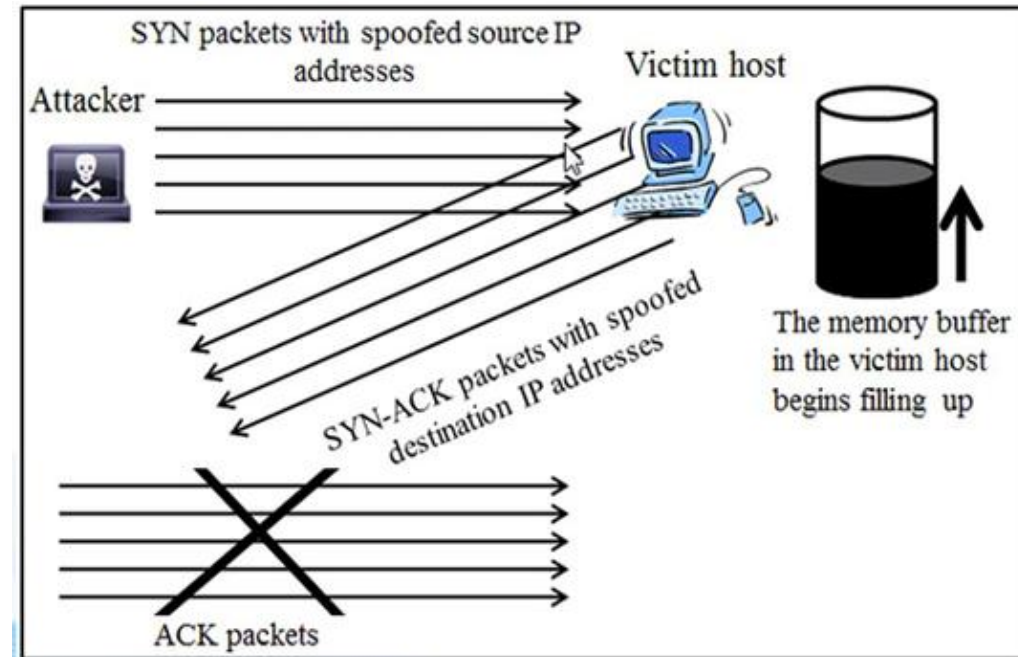
☐ Mạng hoặc máy tính cụ thể

- Làm nghẽn mạng nội bộ (LAN/WAN) để gây gián đoạn hoạt động
- Làm quá tải một nút cụ thể: máy chủ, router/firewall, hoặc máy khách

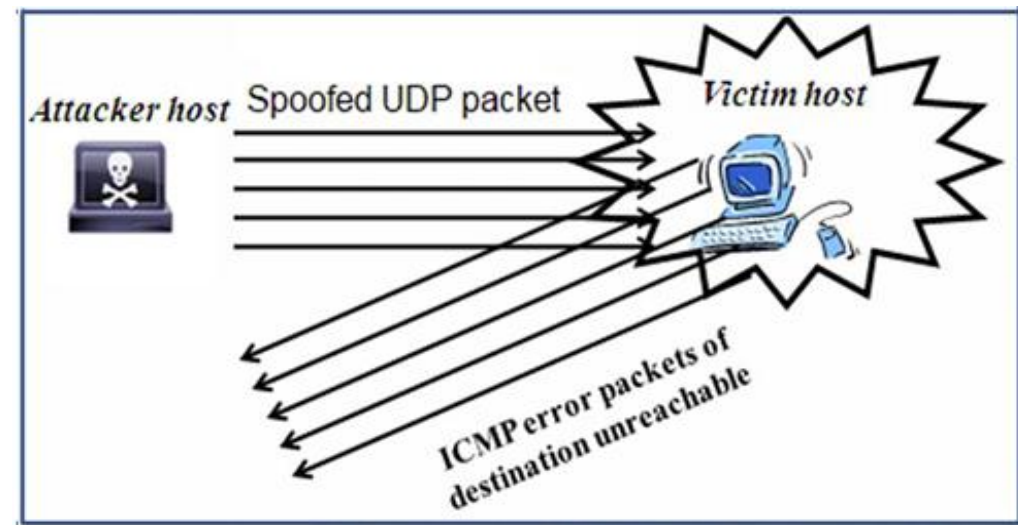
Tùy theo phương thức thực hiện mà tấn công DoS có nhiều dạng khác nhau.

- ☐ Flooding (làm nghẽn lưu lượng): TCP (SYN flood), UDP flood, ICMP flood, HTTP flood
- ☐ Protocol/State exhaustion (làm cạn tài nguyên giao thức): Khai thác điểm yếu trong cơ chế xử lý kết nối/trạng thái của TCP/IP hoặc dịch vụ
- ☐ Spoofing (giả mạo địa chỉ nguồn): Thường dùng để che giấu nguồn hoặc phục vụ các kiểu phản xạ/khuếch đại
- ☐ Distributed DoS (DDoS): Tấn công từ nhiều nguồn (botnet) để tăng quy mô và khó chặn hơn
- ☐ Reflection / Amplification:
 - Reflection: “mượn” máy chủ trung gian phản hồi về nạn nhân
 - Amplification: lợi dụng giao thức có phản hồi lớn hơn yêu cầu để khuếch đại lưu lượng

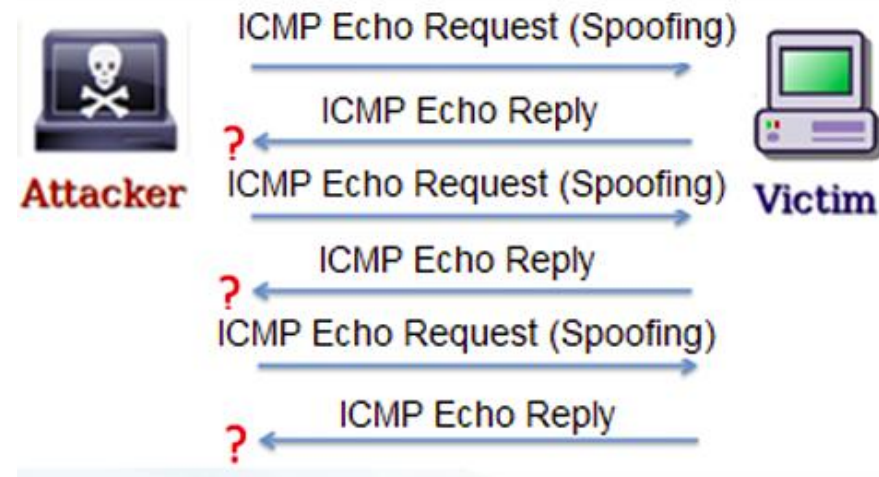
Flooding SYN TCP: các thông điệp giả mạo sẽ được gửi đi liên tục, dẫn đến kết nối không được đóng lại và dịch vụ bị đánh sập.



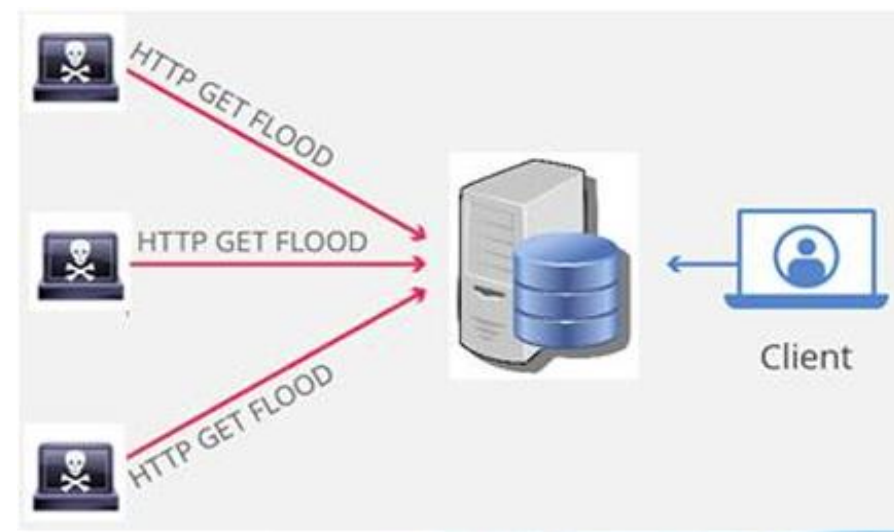
Flooding UDP: một lượng lớn các gói tin UDP được gửi tới cổng ngẫu nhiên trên một Server từ xa, các Server ở xa sẽ trả lời liên tục gói ICMP Destination Unreachable, dẫn đến quá tải



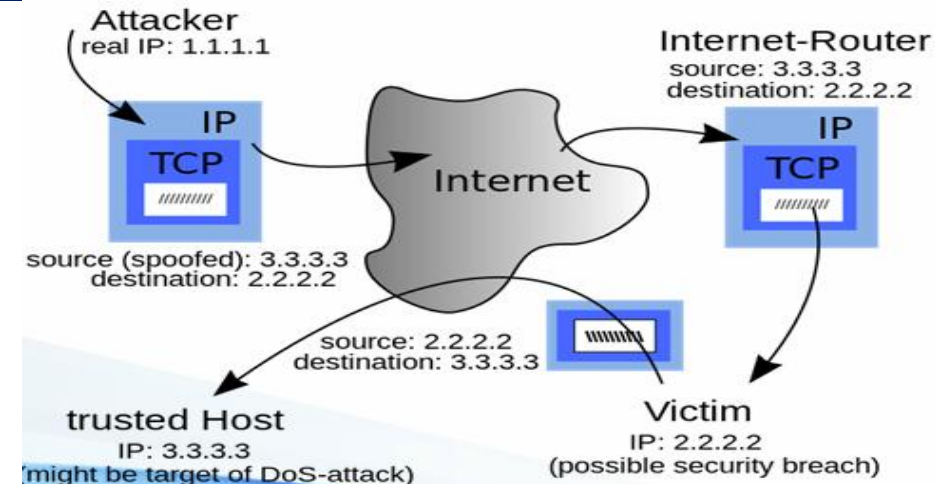
Flooding ICMP Kẻ tấn công làm tràn ngập máy nạn nhân với các gói tin ICMP echorequest và buộc phải trả lời với số lượng gói phản hồi, dẫn đến quá tải.



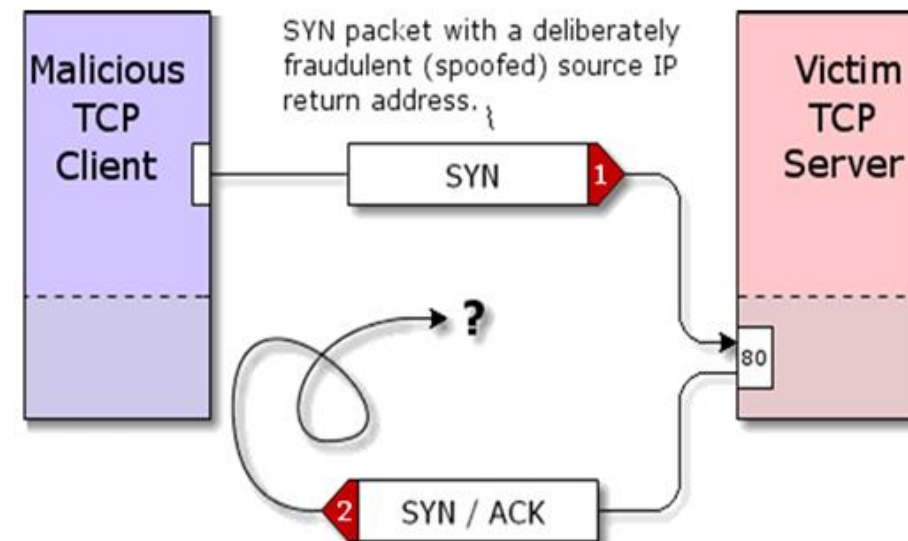
Flooding HTTP gây quá tải bằng cách gửi hàng loạt yêu cầu GET hoặc POST đến Server web, buộc Server sử dụng tối đa nguồn tài nguyên để xử lý tác vụ



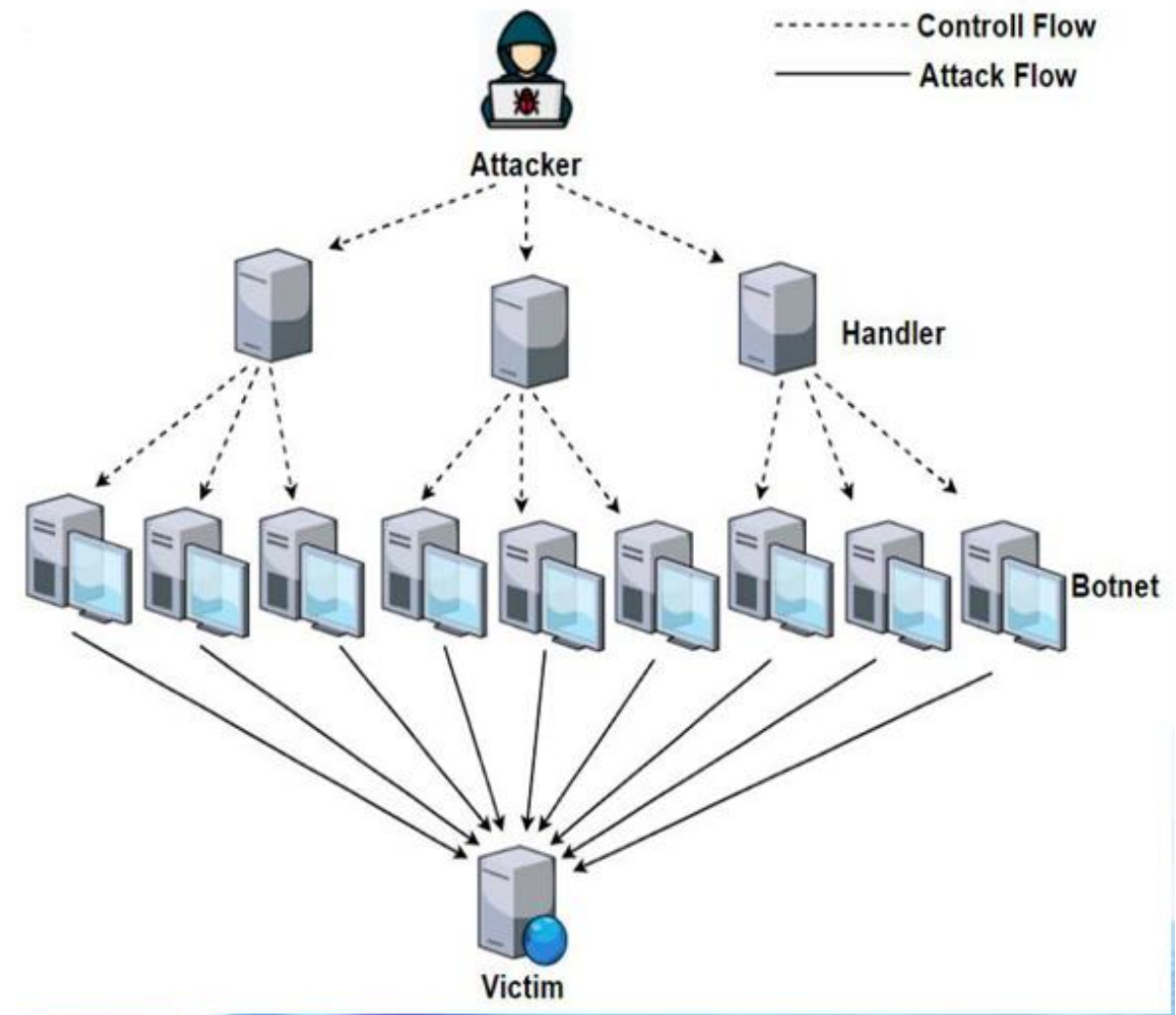
Spoofing source address: gửi đến mục tiêu với các địa chỉ nguồn giả ngẫu nhiên khác nhau, gây ra các phản hồi liên tục từ máy mục tiêu dẫn đến tắc nghẽn



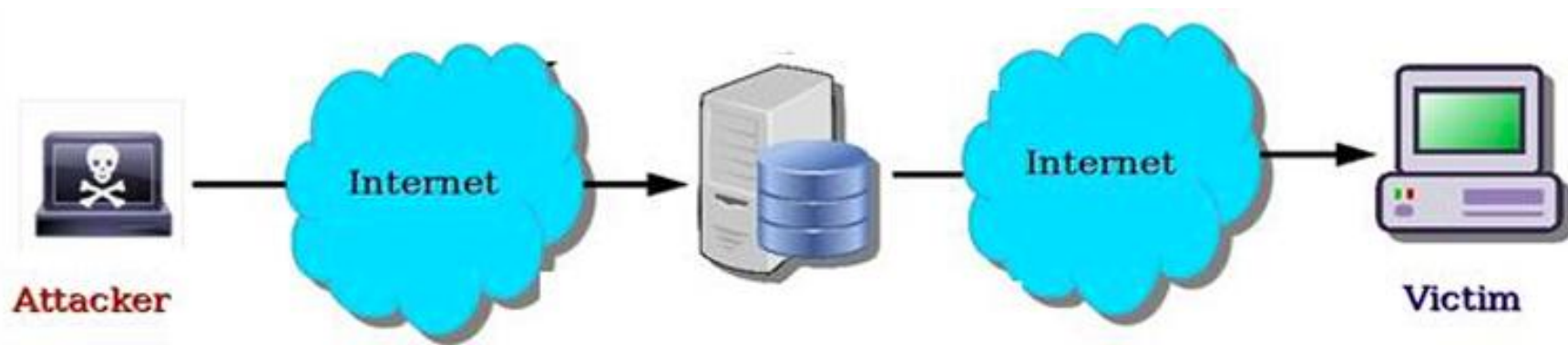
Spoofing SYN: giả mạo SYN để gửi đến Server mục tiêu nhằm tạo ra một số gói yêu cầu kết nối SYN với các địa chỉ nguồn giả mạo, server sẽ Reply đến mức quá tải



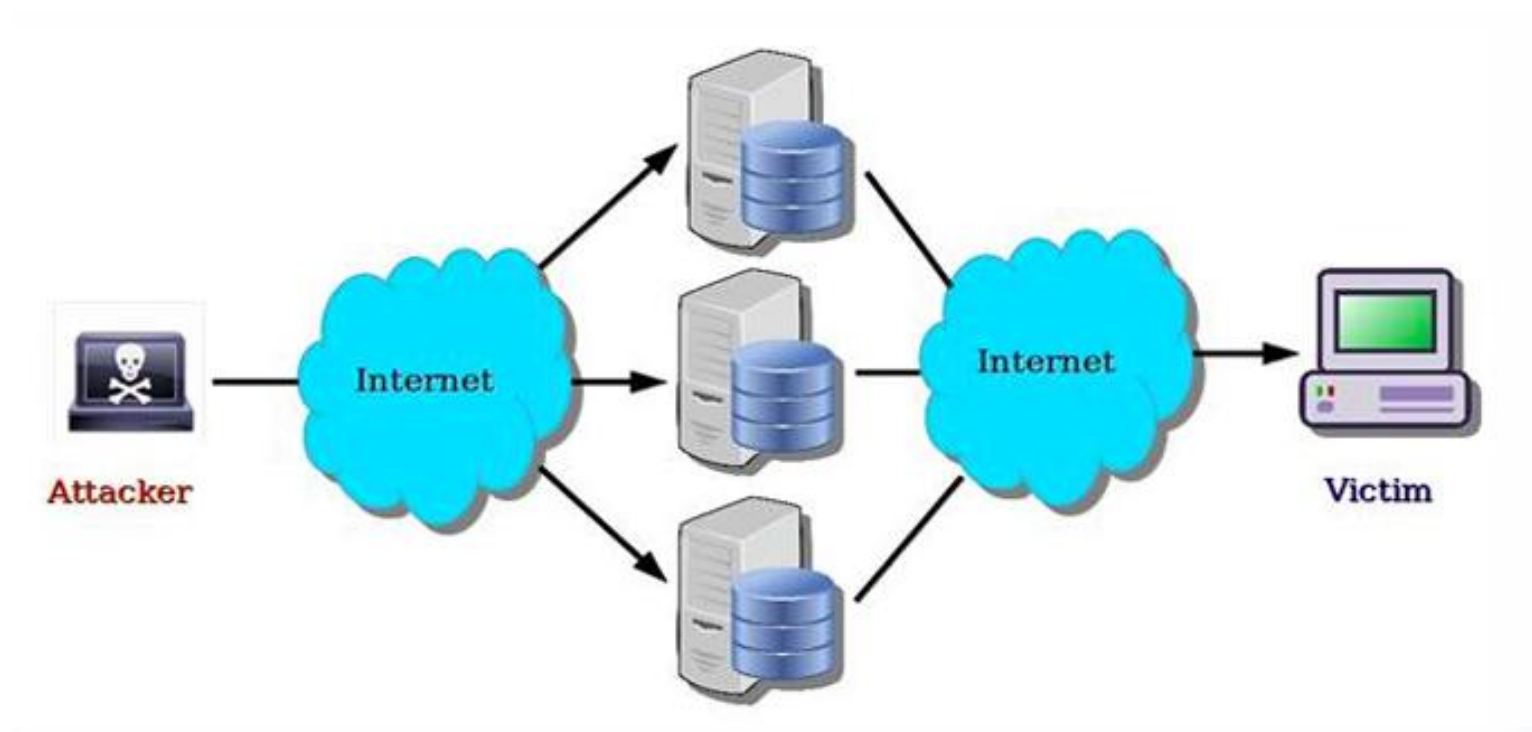
- ❑ Distributed DoS (DDoS): nó được phân tán từ nhiều nguồn tấn công vào một mục tiêu, nhằm vào việc chiếm dụng băng thông, gây nghẽn dẫn đến hệ thống ngưng hoạt động
- ❑ Cách thực hiện kẻ tấn công tìm cách chiếm dụng và điều khiển nhiều máy tính/mạng máy tính trung gian (đóng vai trò zombie) từ nhiều nơi để đồng loạt gửi ào ạt các gói tin với số lượng rất lớn



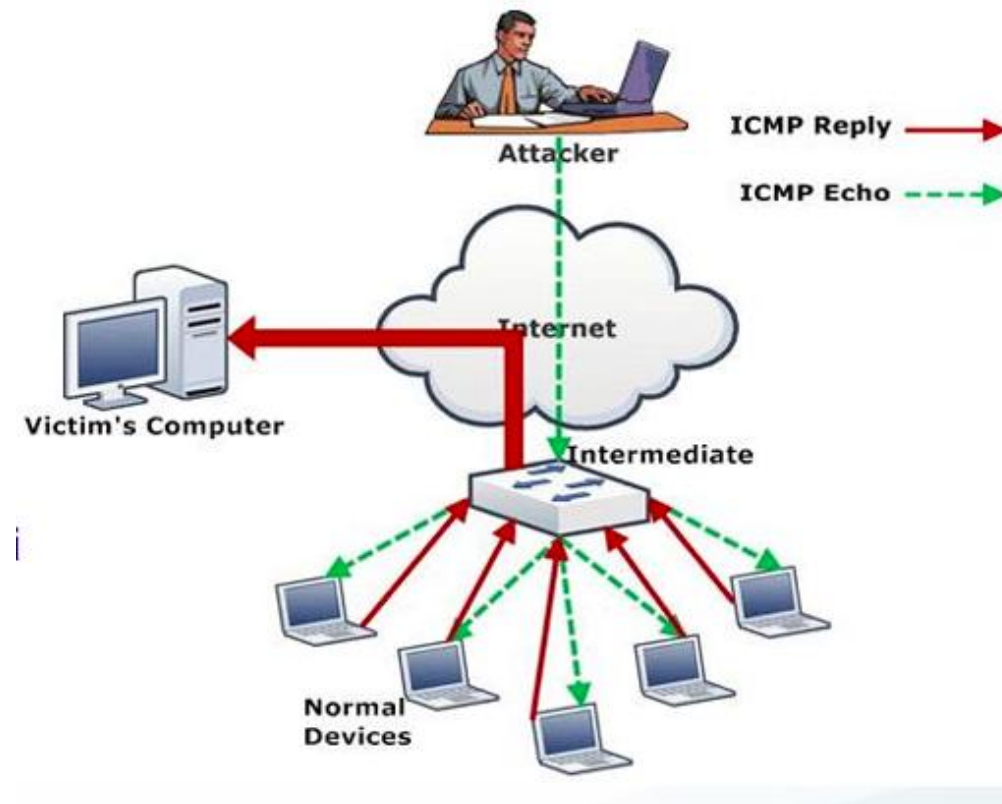
Reflection DoS: kẻ tấn công giả mạo địa chỉ nguồn gửi một số yêu cầu đến một số Server, Server phản hồi lại gói tin này và gửi nó tới địa chỉ nguồn giả mạo chính là đích tấn công thực. Kết quả các phản hồi có thể lấn át liên kết mạng của máy mục tiêu



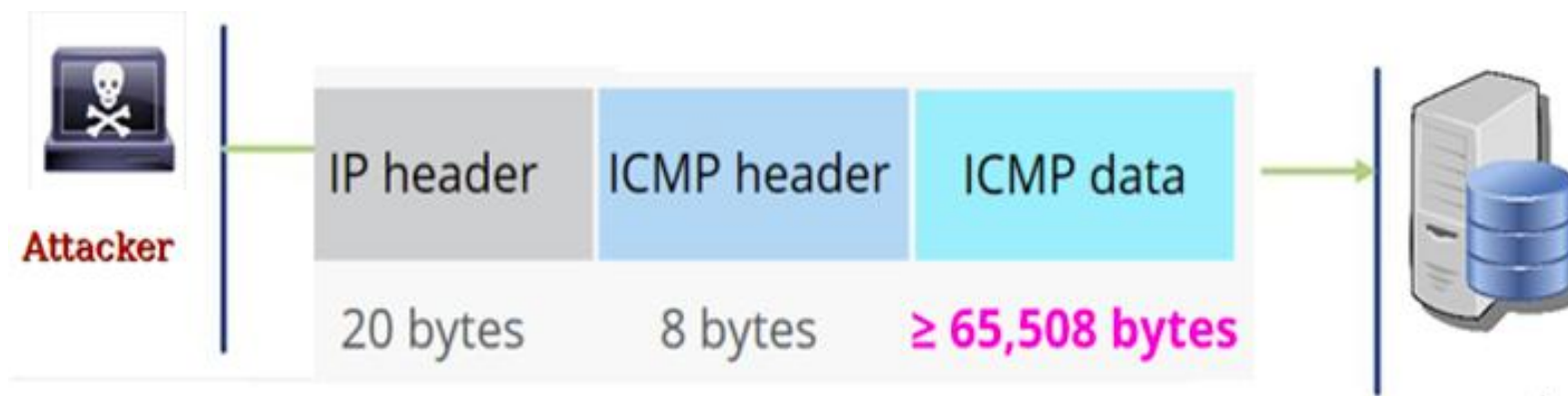
Amplification DoS: dạng biến thể của Reflection DoS, nó thường được thực hiện với dịch vụ DNS, gọi là DNS amplification. Kết quả làm gia tăng traffic không cần thiết, làm suy giảm băng thông của mục tiêu



Amplification DoS: Kẻ tấn công gửi gói tin ICMP echo request với địa chỉ đích là dạng broadcast và địa chỉ nguồn là địa chỉ của Victim. Theo đó thì tất cả các máy nằm trong mạng khuếch đại sẽ đồng loạt trả lời về địa chỉ nguồn (Victim) bằng gói tin ICMP echo reply với đích là máy Victim. Kết quả là máy tính này sẽ không thể xử lý kịp thời một lượng lớn thông tin và dẫn tới bị treo máy.



Ping of Death: là kỹ thuật tấn công làm quá tải hệ thống mạng bằng cách gửi các gói tin ICMP có kích thước vượt quá 65.536 byte đến mục tiêu. Khi đến mục tiêu, nó sẽ được ráp lại thành gói tin hoàn chỉnh, do có kích thước quá mức cho phép, nó sẽ gây ra tràn bộ nhớ đệm và bị treo.



- ☐ Lọc & chặn lưu lượng bất thường trên router/firewall/WAF (ACL, IPS) và cơ chế giảm SYN flood (SYN cookies, connection limits).
- ☐ Giảm bề mặt tấn công: chỉ mở các dịch vụ/cổng cần thiết, tắt service không dùng.
- ☐ Giới hạn tài nguyên theo người dùng (rate limiting/quota): hạn chế request/giây, kết nối đồng thời, băng thông.
- ☐ Giám sát & vá lỗi định kỳ: cập nhật hệ điều hành/ứng dụng, phát hiện cấu hình yếu và lỗ hổng.
- ☐ Dự phòng & phân tán tải: load balancer, auto-scaling, hệ thống dự phòng/đa vùng (HA), kế hoạch ứng cứu.

- ❑ Sniffing là quá trình bắt (capture) và phân tích các gói tin khi chúng truyền trên mạng, nhằm theo dõi nội dung/metadata của lưu lượng.
- ❑ Kẻ tấn công thường bật promiscuous mode trên card mạng, hoặc dùng port mirroring/TAP, hoặc thực hiện MITM (ví dụ ARP spoofing) để thu được lưu lượng không gửi trực tiếp đến máy mình.



Có hai kiểu

- ❑ Sniffing thụ động (Passive sniffing): Chỉ nghe lén và bắt gói tin không tạo lưu lượng giả. Thường hiệu quả trong môi trường Hub, Wi-Fi mở, hoặc khi có port mirroring/TAP.
- ❑ Sniffing chủ động (Active sniffing): Kẻ tấn công tạo can thiệp để chuyển hướng/ép lưu lượng đi qua máy mình (MITM), ví dụ: ARP spoofing/ARP poisoning, MAC flooding (CAM table overflow), DHCP spoofing, ... Thường dùng trên mạng Switch vì switch không phát tán mọi gói tin như hub.

- ❑ Mã hoá lưu lượng: dùng TLS/HTTPS, SSH, VPN (IPsec/WireGuard/OpenVPN) để nghe lén cũng không đọc được nội dung.
- ❑ Chống MITM lớp 2 (đặc biệt ARP spoofing):
 - Bật DHCP Snooping + Dynamic ARP Inspection (DAI) trên switch
 - IP–MAC binding/ARP static cho máy quan trọng (gateway, server)
- ❑ Hardening hạ tầng mạng: Tắt/kiểm soát port mirroring (SPAN), quản trị switch qua mạng quản trị riêng
- ❑ Xác thực an toàn: ưu tiên Kerberos/NTLMv2, tắt cơ chế yếu (vd. LM/NTLMv1) khi có thể.
- ❑ Giám sát & phát hiện: theo dõi bảng ARP/MAC, cảnh báo khi IP trùng MAC, MAC “nhảy” cổng, hoặc xuất hiện ARP reply bất thường.

- ❑ Session Hijacking là việc kẻ tấn công chiếm quyền phiên làm việc giữa client–server bằng cách lấy/giả mạo session token (thường nằm trong cookie hoặc Authorization header) sau khi người dùng đã đăng nhập, từ đó mạo danh người dùng gửi yêu cầu đến server.
- ❑ Các kỹ thuật chiếm điều khiển phiên
 - Stealing (Token theft): đánh cắp session token (qua XSS, malware, sniffing khi không có TLS, log leak...).
 - Prediction/Guessing: dự đoán token khi token yếu/tuần tự/thiếu ngẫu nhiên.
 - Brute-force: thử nhiều token khả dĩ khi không có rate limit/không khóa, hoặc không đủ entropy.

Quá trình chiếm quyền điều khiển phiên:

- ❑ Đặt vị trí nghe lén / MITM (nếu có): kẻ tấn công tìm cách đứng giữa client–server để quan sát/điều hướng lưu lượng (ví dụ ARP spoofing, rogue AP) khi không có bảo vệ đủ mạnh.
- ❑ Thu thập session token: lấy Session ID/JWT từ cookie hoặc Authorization header (qua XSS, malware, log leak, hoặc sniffing khi không dùng TLS).
- ❑ Chiếm quyền phiên (Replay/Impersonation): dùng token vừa có để gửi request như nạn nhân.
- ❑ Duy trì/gián đoạn để thay thế phiên (tùy kịch bản): có thể ép nạn nhân rút kết nối/đăng xuất để giảm cạnh tranh phiên (một số kiểu “desync”/DoS nhẹ).
- ❑ Thực hiện hành vi trái phép: truy cập dữ liệu, đổi thông tin, thực hiện giao dịch... theo quyền của nạn nhân.

□ Các dạng Session Hijacking

- Hijacking chủ động (Active): kẻ tấn công can thiệp vào luồng trao đổi để chiếm quyền phiên (MITM, packet injection, TCP takeover, replay token...).
- Hijacking bị động (Passive): kẻ tấn công nghe lén để thu thập session token (cookie/JWT). Chỉ được xem là “hijacking” khi token bị lấy và dùng để mạo danh; nếu chỉ quan sát thì là sniffing.

□ Phân loại theo tầng

- **Network-level (TCP session hijacking):** chiếm quyền ở mức TCP (theo dõi sequence number, injection/reset/takeover) — thường cần đứng giữa hoặc quan sát được lưu lượng.
- **Application-level (Web session hijacking):** chiếm quyền ở mức ứng dụng bằng session cookie/JWT (XSS, malware, log leak, token replay). Dù chạy trên HTTPS, vẫn có thể bị nếu XSS/endpoint bị chiếm.

- ❑ Bắt buộc mã hoá đường truyền: dùng HTTPS/TLS mọi nơi, bật HSTS.
- ❑ Bảo vệ session cookie/token:
 - Cookie: Secure, HttpOnly, SameSite
 - Không đưa token lên URL, hạn chế lưu trong localStorage nếu có thể
- ❑ Giảm khả năng đánh cắp token (chống XSS/CSRF):
 - Chống XSS (validate/encode output, CSP)
 - Chống CSRF (CSRF token, SameSite phù hợp)

- ❑ Quản lý vòng đời phiên chặt chẽ:
 - Regenerate session ID sau login
 - Timeout hợp lý, logout/invalidate khi đổi mật khẩu
- ❑ Xác thực mạnh: MFA, phát hiện đăng nhập bất thường.
- ❑ Giới hạn & giám sát: rate limit, cảnh báo khi phiên đổi IP/UA bất thường (tùy hệ thống), log/audit.

- ☐ Giới thiệu phần mềm độc hại:
- ☐ Đặc điểm, hoạt động
- ☐ Các dạng phần mềm độc hại
- ☐ Virus, Ransomware, Trojan, Backdoor, Spyware, ...
- ☐ Phân tích phần mềm độc hại
- ☐ Phân tích tĩnh, Phân tích động, Kết hợp
- ☐ Các tấn công phổ biến

1. Mã độc nào sau đây sống độc lập?

- a. Virus**
- b. Worm**
- c. Trojan**
- d. Backdoor**

2. Mã độc nào có lây nhiễm?

- a. Virus**
- b. Adware**
- c. Trojan**
- d. Backdoor**

3. Mã độc nào có liên quan tổng tiền?

a. Rootkit

b. Ransomware

c. Trojan

d. Backdoor

4. Mã độc nào có thể thay đổi lời gọi hệ thống trong HĐH?

a. Rootkit

b. Worm

c. Spyware

d. Backdoor

5. Mã độc nào vượt qua vòng xác thực người dùng thông thường để vào máy?

a. Rootkit

b. Ransomware

c. Trojan

d. Backdoor

6 . Mã độc bí mật chiếm quyền điều khiển hàng trăm hoặc hàng nghìn máy tính?

a. Bot

b. Ransomware

c. Trojan

d. Backdoor



AN TOÀN THÔNG TIN (INSE330380)

Kết thúc chương 5

Ths. ĐỖ MINH HẬU



Trung tâm Học liệu và Dạy học số
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh
daotaotuxa@hcmute.edu.vn